

13

Filter text

Show filters

Sort by Last activity

Programs All

7 of 7 items shown

NOT APPLICABLE8/12/2026, 6:31:49 AM

Critical

NOT APPLICABLE8/7/2026, 12:12:36 AM

High

OUT OF SCOPE8/6/2026, 4:50:44 PM

Account Takeover via Email Change without CSRF/Re-auth...

High

ARCHIVED6/28/2026, 8:00:03 PM

OAuth Open Redirect + Arbitrary Identity Level Injection I...

Low

ARCHIVED6/17/2026, 2:47:35 AM

Cross-Tenant JWT Trust on

Evolutional

Dashboard

Programs

Inbox

API - Accepts Any Token Including Forg

Request support

Code: AXELSPRINGERSE-AB4Y3E0L

LAST UPDATED8/12/2026, 6:31:49 AM

CREATED8/12/2026, 1:57:32 AM

SEVERITYCritical | 9.4

STATUSCritical

BOUNTY€0

BONUS€0

TYPEUse of a Broken or Risky Cryptographic Algorithm

Report

Asset

Endpoint / vulnerable component

Proof of Concept / description

Impact

Attachments

IP address used for testing

Endpoint / vulnerable component

https://api/login/session

Proof of Concept / description

1. Token Extraction: Login to with test account → Extract asid cookie from browser DevTools (Application → Cookies → welt.de)

2. Token Validation: Run get_clean_token.py → Paste cookie value → Confirm token starts with eyJraWQl, has exactly 2 dots, decodes to valid JWT (RS256 algorithm)

3. Legitimate Token Test: Run simple_exploit_test.py → Observe legitimate token returns 200 OK with HTML response containing consumerweb bundle

4. None Algorithm Attack (CVE-2015-9235): simple_exploit_test.py automatically forges token with alg="none" → Returns 200 OK with identical successful response

5. RS256 → HS256 Confusion Attack (CVE-2016-5431): simple_exploit_test.py automatically forges token using server's public key as HMAC secret → Returns 200 OK

6. JWK Injection Attack (CVE-2018-0114): simple_exploit_test.py automatically forges token with injected attacker-controlled JWK header → Returns 200 OK

7. Missing Validation Proof: Run quick_test.py → Observe all three tokens return 200 OK:

Legitimate Token: 200

Invalid Token: 200

Forged Token (none alg): 200

→ Conclusion: Endpoint does not validate the asid token signature

Evidence Included: Screenshots showing each step (token extraction, cleaning, test results), plus the exploit scripts (get_clean_token.py, simple_exploit_test.py, quick_test.py) and response files demonstrating successful authentication with forged tokens.

Impact

1. Authentication Bypass: Complete

The endpoint accepts forged JWT tokens with invalid signatures (including alg="none")

Attackers can create valid-session tokens for any user without knowing their credentials

Validated by all three attack vectors returning HTTP 200 OK with successful responses

2. Account Takeover (ATO): Possible for any user

Demonstrated by injecting admin=true claim into forged tokens

Successful authentication with elevated privileges confirmed in testing

Affects administrators, executives, regular users - any account on the platform

3. Business Impact: Critical

As explicitly documented: "Business Impact: Critical (CVSS 9.8-10.0)"

Potential unauthorized access to sensitive user data including:

Personally Identifiable Information (PII)

Subscription and payment information

Reading history and preferences

Account settings and preferences

Financial risk from exposed payment/subscription details

Reputational damage from privacy violations

Potential GDPR compliance issues if personal data accessed without authorization

4. Exploit Characteristics:

Attack Complexity: Low - simple token forgery with provided scripts

Privileges Required: None - unauthenticated attacker can exploit

User Interaction: None - no action needed from victim

Proof of Concept: Reproducible in under 30 seconds with fresh token

Evidence: Screenshots, terminal outputs, and response files confirm exploit success

5. Technical Confirmation:

Legitimate, invalid, and forged tokens all return identical 200 OK responses

This proves the endpoint does NOT validate the asid token signature

Missing JWT validation middleware allows acceptance of any token format

Three classic JWT attack vectors (None Algorithm, RS256 → HS256 confusion, JWK Injection) all confirmed working

The vulnerability represents a complete failure of the JWT authentication mechanism, enabling attackers to bypass authentication and impersonate any user on the Axel Springer platform with minimal effort and no prior privileges

Attachments

Download all attachments (13)

Hide attachments

simple_exploit_test.py

8/12/2026, 1:54:11 AM

quick_test.py

8/12/2026, 1:54:10 AM

get_clean_token.py

8/12/2026, 1:54:09 AM

simple-exploit-test3.jpg

(565295)

8/12/2026, 1:51:08 AM

simple-exploit-test2.jpg

(468697)

8/12/2026, 1:51:07 AM

simple-exploit-test1.jpg

(407906)

8/12/2026, 1:51:05 AM

logged-in.jpg

(103016)

8/12/2026, 1:51:04 AM

input-tokn-simple_exploit_test.jpg

(89879)

8/12/2026, 1:51:03 AM

get-clean-2.jpg

(353505)

8/12/2026, 1:51:02 AM

get-clean-1.jpg

(499955)

8/12/2026, 1:51:00 AM

axel_jwt_test-input-token.jpg

(630562)

8/12/2026, 1:50:59 AM

axel_jwt_test1.jpg

(517355)

8/12/2026, 1:50:57 AM

asid-from-cookie.jpg

(793494)

8/12/2026, 1:50:56 AM

IP address used for testing

Activity

Add message

rahadrab [researcher]

8/12/2026, 6:31:49 AM

THANK FOR YOUR FAST REPLY AND ASSESMENT OF MY SUBIT. REALLY LOVE THIS PROGRAM AND WOULD LIKE TO SUBMIT MORE IN THE FUTURE. I WILL STILL LOOK INTO THIS AND IF I AM ABLE TO TO ENUM USER DATA WILL REPORT IT. THANK YOU FOR YOUR TIME, AS I KNOW U HAVE A LOT IN YOUR HANDS. THANK YOU FOR YOUR TIME AGAIN

neho changed the status from

8/12/2026, 5:14:15 AM

Hi rahadrab,

Thank you for your submission.

After a thorough review, we have concluded that your report does not

As a result, we have classified this report as not applicable.

The endpoint you tested returns an identical HTML shell (SPA page) for all requests, including a deliberately invalid token string like "invalid.token.here". This shows the endpoint is publicly accessible by design and does not apply JWT validation to this response, making it a public-facing page rather than an authenticated resource. Because your forged tokens do not grant access to any private user data beyond what is already reachable without authentication, this does not constitute a JWT authentication bypass and lacks a demonstrable security impact.

Kind regards,

neho

rahadrab created the submission

8/12/2026, 1:57:32 AM

© Copyright 2026 by intigriti

Report illegal content

Uptime & status

Legal information

Knowledge base

Terms & conditions

Cookie policy

Cookie settings

Privacy statement